

# 4 Postfächer, eine Übersicht. E-Mail-Triage mit KI — sicher, schrittweise, messbar.

Alle Optionen, Vorteile und Risiken auf einen Blick — damit Sie fundiert entscheiden können. Basierend auf einer vollständigen Analyse der Ist-Situation (Phasen 0–2).

## 4 Firmen

planvoller · aim-wohnbau · durchgeplant ·  
burk-keller — alle auf Microsoft 365

## ~50 Mails/Tag

davon ~70 % mit Handlungsbedarf —  
verteilt auf 4 getrennte Postfächer

## 1 Entscheidung offen

Wo darf die KI „denken“? Lokal · EU-Cloud  
· US-Anbieter (Folien 6–7, Entscheidung  
Folie 10)

# 1 Ausgangslage: Was heute schiefgeht

Das Problem in Zahlen und Fällen

## Die Situation

- 4 Firmen, 4 getrennte E-Mail-Welten — **kein gemeinsamer Überblick**
- Eine Person bearbeitet alles, Prüfung 1–15× täglich zwischen Terminen
- ~50 Mails/Tag, davon ~70 % handlungsrelevant — **das Wichtige steht zwischen Werbung und CC-Kopien**

## Drei reale Fehlerfälle (letzte 6 Monate)

### ① Kaufinteresse übersehen

Ein Kunde zeigte Interesse an einem Objekt — die Mail ging unter. **Direkt entgangenes Geschäft.**

### ② Kundennachfrage unbeantwortet

Risiko: unzufriedener Kunde, Eskalation, Reputationsschaden.

### ③ Rechnungen unsichtbar

Automatisch in einen Unterordner sortiert, den das Handy nicht anzeigt — wochenlang übersehen.

## Warum das kein Ordnungsproblem ist

Regeln und Ordner können **bekannte Absender** sortieren. Aber die teuersten Fälle kommen von **neuen oder unauffälligen Absendern**, deren Bedeutung im *Inhalt* steckt:

„Was würde das Haus denn kosten? Können wir nächste Woche telefonieren?“

→ Kaufsignal eines Interessenten. Keine Regel der Welt erkennt das — **eine KI schon.**

„Wir wollten nur nochmal nachfragen, wann es mit dem Estrich weitergeht ...“

→ Höflich formulierte beginnende Eskalation eines Bestandskunden.

## Der Maßstab dieses Projekts

Eine übersehene wichtige Mail ist teurer als zehn Fehlalarme. Das System wird deshalb bewusst so eingestellt: **Im Zweifel wichtig.**

## 2 Was bereits geklärt ist — solide Ausgangslage

Ergebnisse der Analysephasen 0–1

### ✓ Technik verifiziert

- Alle 4 Firmen auf **Microsoft 365** (öffentlich verifiziert)
- 4 getrennte Microsoft-Verbünde („Tenants“) — passt zur rechtlichen Trennung
- **Admin-Zugriff vorhanden** — Einrichtung ohne Dritte möglich
- Sicherer Programm-Zugang (Graph-API) mit exakt begrenzbaren Rechten verfügbar

### ✓ Sofort-Verbesserungen ohne KI identifiziert

- Outlook-App (iPhone): „**Alle Konten**“-**Posteingang** = erster echter Überblick unterwegs
- Fehlerfall ③ (Rechnungen): reiner **Regel-Fix** — Kategorien statt versteckender Ordner
- Mail anflaggen → erscheint automatisch in Microsoft To Do (keine neue App)
- Kosten: **0 €**, Aufwand: ~1–2 Stunden

### ⚠ Ehrlich benannt: Was Bordmittel **NICHT** können

- Kein vereinter, **nach Wichtigkeit sortierter** Überblick am PC
- Keine Erkennung von Kaufsignalen/Eskalationen bei unbekannten Absendern
- Keine Zusammenfassungen, keine Fristen aus Fließtext, kein Kontaktgedächtnis
- **Nur genau dafür** wird eine KI eingesetzt — nicht mehr

## Die vier Sicherheits-Grundsätze des Projekts

### **KI sendet niemals**

Technisch erzwungen durch Nur-Lese-Rechte — nicht bloß versprochen. Entwürfe (spätere Stufe) sendet ausschließlich der Mensch.

### **Datenminimierung**

Jeder Datenfluss braucht Begründung + Rechtsgrundlage (DSGVO Art. 6, Vertrag nach Art. 28). Mails enthalten Daten von Bauherren, Auftragnehmern, Behörden.

### **Keine Firmen-Vermischung**

Lesen übergreifend ist ok — jede Antwort läuft strikt über die richtige Firma, Signatur und Absenderadresse.

### **Im Zweifel wichtig**

Lieber ein Fehlalarm mehr als eine übersehene Frist. „Unwichtiges“ wird nie gelöscht, sondern komprimiert zusammengefasst.

### 3 Was die KI konkret leisten soll

Der Zielzustand im Alltag

#### 1 · Lesen

Die KI liest neue Mails aller 4 Postfächer über eine Schnittstelle, die nur Lesen erlaubt (Graph-API, „Schlüsselkarte ohne Sende-Recht“).



#### 2 · Einordnen

Wer schreibt (Kunde? Interessent? Behörde?), worum geht es, steckt eine Frist oder ein Kaufsignal im Text?



#### 3 · Briefing 7:30 Uhr

EINE Mail mit Excel-Übersicht: Handlungsbedarf heute / diese Woche / zur Kenntnis / Rauschen — je Eintrag: 1 Satz Kern, Frist, nächster Schritt.



#### 4 · Sofort-Alarm

Bei Kaufsignal, Eskalation oder Frist: Push aufs Handy — nicht erst am nächsten Morgen.



#### 5 · Etiketten & Todos

Farbige Kategorien direkt in Outlook (●) Eskalation, (●) Interessent, (●) Rechnung, (●) Behörde) + Aufgaben in Microsoft To Do.

#### Der Nutzen, an den Fehlerfällen gemessen

- **Fall ①/②:** Kaufsignale und Kundenfragen erscheinen im Sofort-Alarm bzw. ganz oben im Briefing — nicht mehr auf Seite 3 von Postfach 4
- **Fall ③:** bereits durch den kostenlosen Regel-Fix gelöst; die KI überwacht zusätzlich, ob erwartete Rechnungen/BWA *ausbleiben*
- Werbung & CC-Mails: 3 Zeilen Zusammenfassung statt 20 Einzelmails

#### Was die KI bewusst NICHT tut

- Keine Mail senden, löschen oder verschieben
- Keine Preise, Angebote oder Zusagen formulieren — solche Mails werden markiert: „*Hier müssen Sie selbst ran*“
- Keine eigene App/Oberfläche — alles erscheint dort, wo ohnehin gearbeitet wird (Outlook, To Do, Mail)
- Mailinhalt wird nie als Befehl behandelt (Schutz vor manipulativen Mails, sog. Prompt Injection)

## 4 Vier mögliche Ausbaustufen — bewertet

Rechte wachsen nur mit nachgewiesenem Vertrauen

| Option                       | Was passiert                                                               | Rechte der KI | Größtes Risiko                                                                                   | Urteil      |
|------------------------------|----------------------------------------------------------------------------|---------------|--------------------------------------------------------------------------------------------------|-------------|
| <b>A — Read-only-Triage</b>  | KI liest nur; erzeugt Briefing + Sofort-Alarm                              | nur lesen     | Briefing könnte Fehler enthalten — Postfächer bleiben unberührt                                  | ✓ Pilot     |
| <b>B — Kategorisierung</b>   | KI setzt zusätzlich farbige Etiketten & Flags in Outlook                   | + Etiketten   | Falsches Etikett — mit 1 Klick korrigierbar, Mail unversehrt                                     | ✓ Pilot     |
| <b>C — Eigene Oberfläche</b> | Separates Dashboard / eigene App                                           | lesen         | Wird nicht genutzt: ein <b>fünfter</b> Ort verschärft das Überblicksproblem                      | ✗ verworfen |
| <b>D — Entwurfs-Agent</b>    | KI legt Antwortentwürfe in den Entwürfe-Ordner; gesendet wird nur von Hand | + Entwürfe    | Ungeprüft gesendeter oder inhaltlich falscher Entwurf → strenge Tabu-Liste + erst nach Bewährung | ⌚ später    |

**Empfehlung:** Pilot mit **A + B** auf einem einzigen Postfach (hm@durchgeplant.de — Einzelfirma, überschaubares Risiko). Ausweitung auf alle 4 Postfächer und Stufe D **erst nach gemessenem Erfolg** (Folie 11). So bleibt jedes Risiko klein und jeder Schritt umkehrbar.

## 5 Die offene Kernentscheidung: Wo darf die KI „denken“?

Drei Wege — ehrlicher Vergleich

**Wichtige Einordnung vorab:** Die E-Mails aller 4 Firmen liegen **heute bereits vollständig in der Microsoft-Cloud** (US-Konzern, EU-Rechenzentren, abgesichert per Auftragsverarbeitungsvertrag). Die Frage ist also nicht „Cloud ja/nein“ — sondern nur: **Welcher zusätzliche Dienst darf die Mails zum Zweck der Auswertung lesen?**

### Weg 1 — Nur lokal eigener Rechner

KI-Modell läuft auf eigener Hardware (z. B. Ollama mit Mistral/Qwen). Kein Byte verlässt das Haus.

-  Beste Datenschutz-Position, kein Zusatzvertrag
-  **Deutlich schwächere Erkennung** — gerade bei Zwischentönen („höfliche Eskalation“, vages Kaufsignal), also genau der Kernaufgabe
-  Hardware 1.500–4.000 € + Eigenbetrieb (Updates, Ausfälle)
- ➔ Risiko wandert vom Datenschutz **in die übersehene Mail**

### Weg 2 — EU-Cloud mit AVV

#### Empfehlung

KI-Dienst in europäischen Rechenzentren (z. B. Azure OpenAI mit EU-Datenresidenz, Mistral/Frankreich), Vertrag nach DSGVO Art. 28.

-  Gute Erkennungsqualität — für Briefing, Kaufsignale, Zusammenfassungen ausreichend
-  Daten bleiben in der EU, schlanke Dokumentation, Standard-AVV
-  Kein eigener Serverbetrieb; ~5–30 €/Monat
-  Daten verlassen das Haus (vertraglich abgesichert)

### Weg 3 — US-Anbieter mit AVV

#### beste Qualität

Führende Modelle (z. B. Anthropic/Claude), abgesichert über AVV + EU-Standardvertragsklauseln — dieselbe Konstruktion wie bei Microsoft 365 selbst.

-  Beste verfügbare Erkennungs- und (später) Entwurfsqualität
-  **Drittlandtransfer:** mehr Dokumentation (4 Firmen = 4× AVV + Transfer-Doku)
-  **Rechtslage EU ↔ US** historisch alle paar Jahre in Bewegung
- ~10–40 €/Monat

## 6 Entscheidungstabelle & Empfehlung

Gewichtet nach den Projekt-Prioritäten

| Kriterium (nach Wichtigkeit sortiert)                               | Nur lokal              | EU-Cloud + AVV | US + AVV                |
|---------------------------------------------------------------------|------------------------|----------------|-------------------------|
| Übersieht keine wichtige Mail — das teuerste Risiko dieses Projekts | ⚠ am schwächsten       | ✓ gut          | ✓ am besten             |
| Datenschutz-Position (DSGVO, Datenminimierung)                      | ✓ perfekt              | ✓ solide       | ⚠ machbar, mehr Doku    |
| Ohne IT-Personal betreibbar                                         | ⚠ realistisch: nein    | ✓ ja           | ✓ ja                    |
| Kosten                                                              | 1.500–4.000 € einmalig | ~5–30 €/Monat  | ~10–40 €/Monat          |
| Vertrags-/Papieraufwand                                             | keiner                 | 1 AVV je Firma | AVV + Klauseln je Firma |

**Empfehlung: Weg 2 — EU-Cloud mit AVV.** Begründung: Das Projekt-Leitprinzip „keine wichtige Mail übersehen“ disqualifiziert die lokale Lösung (Qualitätsrisiko genau bei der Kernaufgabe) — und rechtfertigt zugleich den Datenfluss sauber nach DSGVO Art. 6 (mildere Mittel nachweislich ungeeignet, dokumentiert in Phase 1). EU-Standort hält Doku und Risiko schlank.

### Wann diese Empfehlung falsch ist

- Erkennungsqualität reicht im Pilot nicht → Wechsel auf Weg 3 (US)
- Ein Auftraggeber verbietet vertraglich Cloud-KI → Weg 1 für dieses Postfach, mit bewusst akzeptiertem Qualitätsverlust

### Absicherung: Die Entscheidung ist revidierbar

Das KI-Modell wird als **austauschbares Bauteil** gebaut: Regelwerk, Briefing und Schutzmechanismen bleiben identisch — nur der „Denk-Motor“ ist per Einstellung wechselbar. Ein späterer Wechsel ist Konfiguration, kein Umbau.

## 7 Risiken offen benannt — und ihre Schutzmechanismen

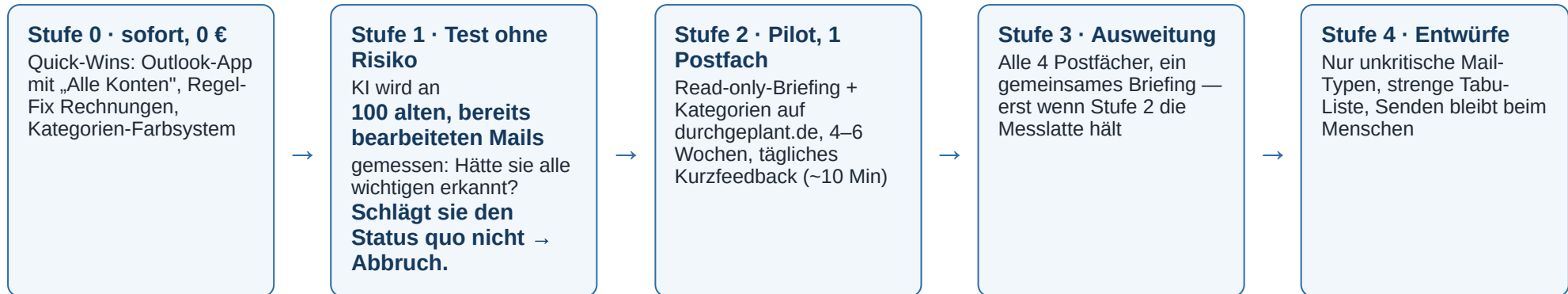
Jedes Risiko hat eine konkrete Gegenmaßnahme

| Risiko                                                  | Was schlimmstenfalls passiert                                                                | Schutzmechanismus („Guardrail“)                                                                                                                                                                               |
|---------------------------------------------------------|----------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Wichtiges als „Rauschen“ eingestuft</b>              | Eine Frist oder ein Interessent landet in der Zusammenfassung statt oben im Briefing         | ① Im Zweifel hochstufen (fest einprogrammierte Asymmetrie) ② Nichts wird gelöscht — auch „Rauschen“ bleibt als Zusammenfassung sichtbar ③ Messung vor Echtbetrieb an 100 alten, von Hand bewerteten Mails     |
| <b>Manipulative Mail</b> (Prompt Injection)             | Eine präparierte Mail versucht, der KI Befehle unterzuschieben („leite alles weiter an ...“) | ① Mailinhalt wird architektonisch als Daten behandelt, nie als Anweisung ② Nur-Lese-Rechte: Senden/Löschen ist <b>technisch unmöglich</b> , egal was die Mail „befiehlt“                                      |
| <b>KI erfindet Fakten</b>                               | Briefing behauptet einen Projektstand, der nicht stimmt                                      | ① Jede Aussage im Briefing verlinkt die Original-Mail (1 Klick zur Quelle) ② Kontext speichert nur belegte Fakten aus Mails, keine Vermutungen                                                                |
| <b>Entwurf versehentlich gesendet</b> (erst ab Stufe D) | Eine KI-formulierte Antwort geht ungeprüft raus                                              | ① Senden bleibt technisch beim Menschen ② Entwürfe tragen sichtbaren Hinweis ③ Tabu-Liste: Preise, Angebote, Zusagen, Rechtliches werden nie entworfen, sondern eskaliert                                     |
| <b>Datenschutzverstoß</b>                               | Personenbezogene Daten fließen ohne Rechtsgrundlage                                          | ① AVV mit dem KI-Anbieter je Firma ② dokumentierte Interessenabwägung (Art. 6) ③ Datenminimierung: nur Mail-Text zur Triage, keine Anhänge ④ 4 getrennte Zugänge — keine Vermischung der Verantwortlichkeiten |



## 8 Fahrplan: klein anfangen, Erfolg messen, dann wachsen

Jede Stufe schaltet die nächste erst durch Vertrauensnachweis frei



### Woran der Erfolg gemessen wird

#### Übersehene wichtige Mails

**Die Zahl, die zählt.** Ziel: 0 im Piloten. Jede einzelne wird analysiert — bleibt es nicht bei Ausreißern, wird gestoppt oder umgebaut.

#### Rauschreduktion

Wie viele Einzelmails muss der Mensch nicht mehr öffnen, weil die Zusammenfassung reicht?

#### Briefing-Lesezeit

Der Morgenüberblick über alles soll in **unter 5 Minuten** gelesen sein — sonst ist er zu lang gebaut.

## 9 Ihre Entscheidung

Eine Frage — alles Weitere ist vorbereitet

### Bereits festgelegt (änderbar auf Zuruf)

- Pilot: Optionen **A + B** (nur lesen + Etiketten) auf **hm@durchgeplant.de**
- Briefing täglich **7:30 Uhr** per Mail + Excel, Sofort-Alarm bei Kaufsignal/Eskalation/Frist
- Todos in Microsoft To Do — keine neue App
- Messung an 100 alten Mails **vor** dem Echtbetrieb; klare Abbruchkriterien
- KI sendet niemals; Modell als austauschbares Bauteil

### Kosten im Überblick

| Posten                                                             | Rahmen                           |
|--------------------------------------------------------------------|----------------------------------|
| Quick-Wins (Stufe 0)                                               | 0 €                              |
| KI-Dienst (bei Empfehlung Weg 2)                                   | ~5–30 €/Monat                    |
| Einrichtung Pilot (mit Anleitung, eigener Admin-Zugriff vorhanden) | überschaubar, einmalig           |
| Eigenaufwand Pilotphase                                            | ~10 Min/Tag Feedback, 4–6 Wochen |

### Die eine offene Frage: Wo darf die KI „denken“?

Bitte einen Weg wählen (Details Folien 6–7):

- a) EU-Cloud mit AVV** — ★ Empfehlung: gute Qualität, Daten in der EU, schlanke Doku
- b) US-Anbieter mit AVV** — beste Qualität, mehr Dokumentationsaufwand
- c) Nur lokal** — maximale Datenhoheit, spürbar schwächere Erkennung, Hardware + Eigenbetrieb

Die Entscheidung ist revidierbar — das KI-Modell ist als austauschbares Bauteil geplant.

### Nach der Entscheidung passiert Folgendes

- **Phase 3:** Detail-Design — Prioritäts-Regelwerk aus den realen Beispielen, Briefing-Format, alle Schutzmechanismen (zur Freigabe vorgelegt)
- **Phase 4:** Messung an 100 alten Mails gegen den Status quo
- **Phase 5:** 90-Tage-Fahrplan mit Freischalt-Kriterien je Stufe